

Vulnerability Assessment con Nmap e Nessus

S5L4

Titolo Esercitazione	Vulnerability Assessment con Nmap e Nessus
Target	Metasploitable – 192.168.64.11
Ambiente di Lab	Kali Linux (UTM – aarch64) + Metasploitable 2 (VM)
Strumenti Utilizzati	Nmap 7.98, Nessus Essentials
Anno Accademico	2024 / 2025

1. Obiettivo dell'Esercitazione

L'esercitazione richiede di eseguire scansioni di rete, identificare vulnerabilità e valutare i rischi utilizzando strumenti standard di settore come **Nmap** e **Nessus**. Il target è la macchina **Metasploitable 2** (192.168.64.11), una distribuzione Linux intenzionalmente vulnerabile progettata per il pentesting didattico.

2. Ambiente di Laboratorio

L'esercitazione è stata svolta in un ambiente completamente virtualizzato tramite **UTM** su MacBook M4. Le due macchine virtuali comunicano su una rete host-only condivisa nella subnet **192.168.64.0/24**.

Componente	Dettaglio
Kali Linux (attaccante)	VM aarch64 su UTM – IP: 192.168.64.10. Host delle scansioni.
Metasploitable 2 (target)	VM Linux Kernel 2.6, Ubuntu 8.04 Hardy – IP: 192.168.64.11.
Nmap 7.98	Port scanner usato per host discovery e service enumeration.
Nessus Essentials	Vulnerability scanner automatizzato per l'analisi approfondita.
Rete	Host-only 192.168.64.0/24 – isolata, senza accesso a Internet.

3. Procedura Svolta

STEP 1 – Host Discovery: nmap -sn

Il primo passo è stato individuare gli host attivi nella subnet. Ho usato il flag **-sn** (Ping Scan) che esegue solo host discovery senza scansione delle porte, rendendolo rapido e silenzioso.

Senza privilegi (nmap -sn)

```
$ nmap -sn 192.168.64.0/24
Starting Nmap 7.98 at 2026-05-07 10:26
Nmap scan report for 192.168.64.1 – Host is up (0.00067s latency)
Nmap scan report for 192.168.64.11 – Host is up (0.0017s latency)
MAC Address: 46:54:CE:86:FA:C0 (Unknown)
Nmap scan report for 192.168.64.10 – Host is up
Nmap done: 256 IP addresses (3 hosts up) scanned in 3.04 seconds
```

Con privilegi root (sudo nmap -sn)

```
$ sudo nmap -sn 192.168.64.0/24
Starting Nmap 7.98 at 2026-05-07 10:47
Nmap scan report for 192.168.64.1 – Host is up (0.00058s latency)
MAC Address: A2:9A:8E:51:4B:64 (Unknown)
Nmap scan report for 192.168.64.11 – Host is up (0.0040s latency)
MAC Address: 46:54:CE:86:FA:C0 (Unknown)
Nmap scan report for 192.168.64.10 – Host is up
Nmap done: 256 IP addresses (3 hosts up) scanned in 3.04 seconds
```

Differenza senza/con sudo: senza privilegi root Nmap non può inviare pacchetti ARP grezzi e utilizza tecniche alternative (TCP SYN su porta 443 e ICMP echo). Con sudo ottiene i MAC address completi grazie all'ARP scan. In entrambi i casi vengono rilevati gli stessi 3 host.

STEP 2 – TCP Connect Scan: `sudo nmap -sT 192.168.64.11`

Il TCP Connect Scan (**-sT**) completa il three-way handshake TCP (SYN → SYN-ACK → ACK) per ogni porta testata. È il tipo di scansione più affidabile ma anche il più rumoroso e facilmente rilevabile da un IDS.

STEP 3 – SYN Scan (Stealth): `sudo nmap -sS 192.168.64.11`

Il SYN Scan (**-sS**, detto anche half-open scan) invia un pacchetto SYN e, al ricevere SYN-ACK, risponde con RST senza completare il handshake. È più veloce e stealth del -sT poiché non apre connessioni complete, difficile da loggare a livello applicativo. Richiede privilegi root per inviare pacchetti grezzi.

Nota: I risultati di -sT e -sS su Metasploitable sono identici – 977 porte chiuse e le stesse 23 porte aperte. La differenza è nel metodo: -sT registra le connessioni (loggabile), -sS non completa il handshake (più difficile da rilevare).

STEP 4 – UDP Scan: `sudo nmap -sU 192.168.64.11`

L'UDP Scan (**-sU**) è molto più lento del TCP (ha impiegato **1020 secondi** – circa 17 minuti) perché UDP non prevede acknowledgment: Nmap deve aspettare timeout per porte che non rispondono. Porta open = risposta UDP ricevuta. open|filtered = nessuna risposta (potrebbe essere aperta o filtrata).

4. Risultati Scansioni Nmap — 192.168.64.11

Porte TCP aperte (-sT / -sS)

Porta/Proto	Stato	Servizio	Note
21/tcp	open	ftp	File Transfer Protocol – spesso con credenziali deboli
22/tcp	open	ssh	Secure Shell – potenziale accesso remoto
23/tcp	open	telnet	Telnet – comunicazione in chiaro, altamente insicuro
25/tcp	open	smtp	Mail Transfer Protocol
53/tcp	open	domain	DNS – anche su TCP per zone transfer
80/tcp	open	http	Web server – interfaccia web esposta
111/tcp	open	rpcbind	RPC Portmapper – usato da NFS e altri servizi NetBIOS
139/tcp	open	netbios-ssn	Session Service (SMB)
445/tcp	open	microsoft-ds	SMB su TCP – Samba, condivisioni file
512/tcp	open	exec	Remote exec – servizio r* legacy insicuro
513/tcp	open	login	Remote login – servizio r* legacy insicuro
514/tcp	open	shell	Remote shell – servizio r* legacy insicuro
1099/tcp	open	rmiregistry	Java RMI Registry
1524/tcp	open	ingreslock	Backdoor nota su Metasploitable

Porta/Proto	Stato	Servizio	Note
2049/tcp	open	nfs	Network File System — condivisioni esposte
2121/tcp	open	ccproxy-ftp	FTP alternativo
3306/tcp	open	mysql	Database MySQL — esposto senza firewall
5432/tcp	open	postgresql	Database PostgreSQL
5900/tcp	open	vnc	VNC — accesso desktop remoto
6000/tcp	open	X11	X Window System — accesso grafico remoto
6667/tcp	open	irc	IRC — UnrealIRCd con backdoor nota
8009/tcp	open	ajp13	Apache JServ Protocol (Ghostcat)
8180/tcp	open	unknown	Apache Tomcat su porta alternativa

Tab. 1 – 23 porte TCP aperte su Metasploitable (192.168.64.11).

Porte UDP aperte (-sU) — durata: ~17 minuti

Porta/Proto	Stato	Servizio
53/udp	open	domain (DNS)
69/udp	open filtered	tftp (Trivial FTP)
111/udp	open	rpcbind
137/udp	open	netbios-ns
138/udp	open filtered	netbios-dgm
2049/udp	open	nfs

Tab. 2 – Porte UDP rilevate. Scan completato in 1020 secondi.

Host rilevati nella subnet 192.168.64.0/24

IP	MAC Address	Latenza	Ruolo stimato
192.168.64.1	A2:9A:8E:51:4B:64	0.00058s	Gateway / Router virtuale UTM
192.168.64.10	–	–	Kali Linux (macchina attaccante)
192.168.64.11	46:54:CE:86:FA:C0	0.0040s	Metasploitable 2 (target)

5. Sfida Extra — Vulnerability Assessment con Nessus

Ho configurato una nuova scansione Nessus di tipo **Basic Network Scan** puntando direttamente all'host Metasploitable (192.168.64.11). La scansione ha richiesto circa **un'ora** per completarsi, data la quantità di servizi esposti e la profondità dell'analisi dei plugin.

Dettagli scansione

Policy	Basic Network Scan
Status	Completed
Severity Base	CVSS v3.0
Scanner	Local Scanner
Target	192.168.64.11
OS rilevato	Linux Kernel 2.6 on Ubuntu 8.04 (hardy)
MAC	46:54:CE:86:FA:C0
Auth	Fail (credenziali non fornite)
Inizio / Fine	Oggi 11:23 AM → 12:39 PM
Durata	~1 ora
Vulnerabilità	88 totali: 12 Critical, 10 High, 33 Medium, 10 Low, 149 Info (sub-items)

Vulnerabilità CRITICAL

Nome	CVSS	VPR	EPSS	Famiglia	N.
UnrealIRCd Backdoor Detection	10.0*	7.4	0.8622	Backdoors	1
Canonical Ubuntu Linux SEoL (8.04.x)	10.0	—	—	General	1
VNC Server 'password' Password	10.0*	—	—	Gain a shell remotely	1
Apache Tomcat AJP Connector (Ghostcat)	9.8	8.9	0.9447	Web Servers	1
SSL Version 2 and 3 Protocol Detection	9.8	—	—	Service detection	2
Bind Shell Backdoor Detection	9.8	—	—	Backdoors	1
Phpmyadmin (Multiple Issues) [MIXED]	—	—	—	CGI abuses	4
SSL (Multiple Issues) [MIXED]	—	—	—	Gain a shell remotely	3
PHP (Multiple Issues) [MIXED]	—	—	—	CGI abuses	3

Tab. 3 – Vulnerabilità Critical rilevate da Nessus.

Vulnerabilità HIGH

Nome	CVSS	VPR	EPSS	Famiglia	N.
rlogin Service Detection	7.5*	6.7	0.5006	Service detection	1
rsh Service Detection	7.5*	6.7	0.5006	Service detection	1
Samba Badlock Vulnerability	7.5	5.9	0.7852	General	1
NFS Shares World Readable	7.5	—	—	RPC	1

Vulnerabilità MEDIUM / MIXED (selezione)

Nome	CVSS	Famiglia	N.
SSL (Multiple Issues) [MIXED]	—	General	28
SSH (Multiple Issues) [MIXED]	—	Misc.	6
ISC Bind (Multiple Issues) [MIXED]	—	DNS	5
DNS (Multiple Issues) [MIXED]	—	DNS	5
HTTP (Multiple Issues) [MIXED]	—	Web Servers	4
TLS Version 1.0 Protocol Detection	6.5	Service detection	2
Unencrypted Telnet Server	6.5	Misc.	1
SSL Anonymous Cipher Suites Supported	5.9	Service detection	1
SSL DROWN Attack Vulnerability	5.9	Misc.	1
Browsable Web Directories	5.3	CGI abuses	1
Backup Files Disclosure	5.0*	CGI abuses	1
Web Application Vulnerable to Clickjacking	4.3*	Web Servers	1
PHP (Multiple Issues) [MIXED]	—	Web Servers	3
Phpmyadmin (Multiple Issues) [MIXED]	—	CGI abuses: XSS	2
SMB (Multiple Issues) [MIXED]	—	Misc.	2
TLS (Multiple Issues) [MIXED]	—	Misc.	2
Twiki (Multiple Issues) [MIXED]	—	CGI abuses	2

Vulnerabilità LOW

Nome	CVSS	VPR	EPSS	Famiglia	N.
SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam3).7		2.9	0.9374	Misc.	1
X Server Detection2.6* ICMP Timestamp Request Remote		—	—	Service detection	1
Date Disclosure2.1*		2.2	0.0037	General	1

Vulnerabilità INFO (principali)

Nome	Famiglia	N.
SMB (Multiple Issues)	Windows	7
TLS (Multiple Issues)	General	4
FTP (Multiple Issues)	Service detection	3
VNC (Multiple Issues)	Service detection	3
Apache HTTP Server (Multiple Issues)	Web Servers CGI	2
HTTP (Multiple Issues)	abuses	2
RPC (Multiple Issues)	RPC	2

6. Analisi dei Risultati

6.1 Analisi Nmap

Metasploitable espone una superficie d'attacco enormemente ampia: **23 porte TCP** e **6 porte UDP** aperte. Tra i servizi più critici spiccano **Telnet (23)** e i servizi **r* (rexec/rlogin/rsh, 512-514)** che trasmettono tutto in chiaro e non richiedono autenticazione forte. La porta **1524 (ingreslock)** è una backdoor classica di Metasploitable che garantisce shell root diretta. La porta **6667 (IRC)** ospita UnrealIRCd con backdoor nota (CVE).

La differenza tra **-sT** e **-sS** è metodologica: entrambi rilevano le stesse porte ma il SYN scan è preferibile in un contesto reale perché è più difficile da loggare. Il flag **-sU** ha richiesto 17 minuti per 994 porte — comune per UDP, che non ha meccanismo di risposta garantito.

6.2 Analisi Nessus

La scansione Nessus ha rilevato **88 vulnerabilità** (12 Critical, 10 High, 33 Medium). Le finding più gravi confermano quanto già osservato con Nmap:

Vulnerabilità	Rischio	Motivazione
UnrealIRCd Backdoor (CVSS 10.0)	CRITICO	Backdoor nel binario IRC: consente accesso shell remota senza autenticazione.
VNC password 'password' (CVSS 10.0)	CRITICO	Password VNC triviale: accesso desktop completo immediato senza ostacoli.
Bind Shell Backdoor (CVSS 9.8)	CRITICO	Shell in ascolto su porta aperta: accesso root diretto senza credenziali.
Apache Ghostcat / AJP (CVSS 9.8)	CRITICO	Local File Inclusion / RCE tramite protocollo AJP esposto su porta 8009.
SSL v2/v3 Detection (CVSS 9.8)	CRITICO	Protocolli SSL obsoleti vulnerabili a POODLE, DROWN e BEAST attack.
Ubuntu 8.04 SEoL (CVSS 10.0)	CRITICO	OS fuori supporto dal 2013: nessuna patch di sicurezza più disponibile.
rlogin / rsh (CVSS 7.5)	ALTO	Autenticazione basata su IP: facilmente aggirabile tramite IP spoofing.
NFS World Readable (CVSS 7.5)	ALTO	Filesystem NFS montabile senza autenticazione da qualsiasi host.
Logjam DH <= 1024 bit (CVSS 3.7)	BASSO	Chiavi Diffie-Hellman deboli: soggette a downgrade attack (FREAK/Logjam).

7. Conclusioni

Questa esercitazione mi ha permesso di acquisire competenze pratiche nell'uso di **Nmap** per la ricognizione di rete e di **Nessus** per il vulnerability assessment automatizzato.

Con **Nmap** ho compreso le differenze tra i vari tipi di scan: il Ping Scan per la discovery, il TCP Connect (-sT) e SYN Scan (-sS) per l'enumerazione delle porte TCP, e l'UDP Scan (-sU) per i servizi UDP. Ho potuto verificare concretamente che Metasploitable espone una superficie d'attacco molto ampia con 23 servizi TCP e 6 UDP attivi.

Con **Nessus** ho eseguito un'analisi automatizzata che ha identificato 88 vulnerabilità, tra cui 12 critiche. Le finding più significative includono backdoor note (UnrealIRCd, Bind Shell), credenziali triviali (VNC), protocolli obsoleti (SSL v2/v3, Telnet, r*-services) e un OS completamente fuori supporto da oltre 10 anni.

Questi risultati confermano che Metasploitable è un laboratorio ideale per la pratica del pentesting.

Report redatto nell'ambito del Corso di Cybersecurity & Ethical Hacking — A.A. 2024/2025